Operation ECHOLEAK · Final Investigation Report

Training context: This investigation was completed in the LogNPacific cyber range using simulated organization and user data. I used guided assistance to develop queries and interpret findings. This report documents a training exercise.

Investigation: Microsoft 365 Copilot prompt injection
Scenario incident date: September 20, 2026
Environment: Cormorant Capital Partners
Tools used: Microsoft Sentinel / Azure Log Analytics (KQL)

What happened

I investigated unusual file activity tied to an employee's Microsoft 365 Copilot session. Emily Chen had asked Copilot to summarize a quarterly report that came through email. That was a normal request. What happened afterward was not.

The document appears to have contained hidden instructions that caused Copilot to search for and open other company files that had nothing to do with the report. The attacker used the document to steer Copilot without needing to log in as Emily or change Copilot's settings.

What I found

I started by checking the Copilot audit logs and matched the activity against the Microsoft 365 file-access logs. Here's what stood out:

- Emily's actual prompt was: **"Summarise the key findings of this quarterly report."**
- Copilot made searches for confidential board minutes, acquisition targets, and salary information, then opened **five unrelated sensitive files** in a rapid burst.
- Those first five files included board meeting minutes, an M&A assessment, a salary review, a client portfolio, and a Copilot configuration file.
- Later, Copilot searched for **confidential, restricted, board, acquisition, and salary** and accessed **eight more files**.
- That makes **13 sensitive files accessed** during the two collection phases.
- Copilot's responses included image links pointing to **metrics-cdn.analyticshub.io**, with encoded information in the URL parameters. When those links are loaded, the request can carry data to the outside domain.
- Copilot also exposed its system prompt and configuration information, which could help an attacker plan another attempt.

Why I believe it was an attack

Normal Copilot activity in the logs involved straightforward tasks such as summarizing a document, explaining a calculation, or creating a chart. This session was different. It had multiple Graph search and file-read calls, first-time access

to unrelated sensitive documents, very fast file retrieval, and external image links in the response.

I also reviewed the incident's sign-in and configuration findings. There was no reported unusual sign-in for Emily, and the evidence showed Copilot's configuration was **exposed**, not changed. The main issue was **indirect prompt injection**: instructions hidden inside outside content were treated as directions by Copilot.

What the logs cannot prove

The logs show which files were accessed and where the suspicious URLs appeared. They do **not** give us the complete contents of every file or confirm exactly what data reached the external server. I would not claim that every bit of all 13 files was stolen without more evidence.

What I would recommend

The security team should preserve the document and relevant audit records, investigate and block the suspicious destination as appropriate, review access to the affected files, and check for any other Copilot sessions showing the same pattern. The organization should also tighten controls around untrusted document content and external links produced in AI responses.

Final assessment

Classification: External input manipulation through indirect prompt injection (MITRE ATLAS **AML.T0051**).

My conclusion is that Copilot was led away from Emily's legitimate request by instructions hidden in a document. The investigation confirmed unauthorized-in-context access to 13 sensitive files, suspicious external image-link behavior, and exposure of system configuration details. The exact data transmitted outside the organization remains unverified from the available logs.